

UNIVERSITY OF SCIENCE AND TECHNOLOGY OF HANOI

Department of Information and Communication Technology

WEEKLY INTERNSHIP REPORT

Week 7 - DFIR-IRIS Response, Reconnaissance Pentesting, and Wazuh-to-IRIS Alert Forwarding Validation Phase

Design and Implementation of an IDS/IPS-Based SOC Platform for Detecting and Preventing Broken Access Control Attacks in REST APIs

Student	Bùi Tt Đt
Major	Cyber Security
Main target	crAPI vulnerable API laboratory
Monitoring platform	Wazuh Manager, Wazuh Indexer, Wazuh Dashboard, containerized Wazuh agents, and DFIR-IRIS
Core engineering focus	Wazuh-to-DFIR-IRIS integration, high-severity alert forwarding, IRIS alert response validation, OWASP ZAP reconnaissance scanning, and row-level Wazuh evidence capture
Current status	The Week 6 source-IP blocker is considered resolved for web/API detections. In Week 7, high-severity Wazuh alerts were successfully forwarded into DFIR-IRIS, and reconnaissance/pentest activity generated observable Wazuh and IRIS evidence.
Supervisor	Tran Dai Duong
Organization	Bglobal

Hanoi, June 3, 2026

Abstract

This weekly report documents the Week 7 progress of the SOC/IDS laboratory after the Week 6 source-IP preservation work. In Week 5, the project validated the custom Wazuh rules but still had an attribution problem because the real Kali attacker IP could be translated by the Docker/NAT path. In Week 6, the architecture was corrected by using Ubuntu-native Docker deployment and an edge reverse proxy so that Wazuh events could include the real Kali source IP, HTTP method, URL, and status code together in the same event.

The Week 7 objective was to move from detection-only validation to incident-response workflow validation. The Wazuh manager and DFIR-IRIS nginx container were connected through a shared Docker network, the IRIS API key workflow was tested, and a custom Wazuh integration script was used to forward high-severity alerts into DFIR-IRIS. The integration is intentionally scoped to higher-value detections: Wazuh alerts with rule level 10 or above and belonging to the bGlobal/crAPI groups are forwarded to IRIS, while lower-severity reconnaissance noise remains available in Wazuh for threat hunting.

Pentest and reconnaissance validation was performed against the crAPI lab using OWASP ZAP and controlled web/API requests. The ZAP automated scan against <http://10.10.1.130:8888> completed and produced 13 alert families, including missing security headers, cookie attributes, information disclosure, suspicious comments, and session-management observations. Wazuh Dashboard evidence also showed a high-severity PHP-CGI option injection attempt with source IP 10.10.1.20, web-gateway agent context, HTTP status 405, and a bGlobal rule level of 10. DFIR-IRIS then showed the alert queue being populated, with created and unassigned alert counts visible in the Statistics page. Additional IRIS alert-list evidence shows individual forwarded Wazuh alerts, including rule 110400 for BFLA/admin endpoint access, rule 110672 for PHP-CGI option injection, rule 110676 for repeated high-entropy path fuzzing, and rule 110311 for SQLi/NoSQLi URL patterns.

The main Week 7 result is that the operational chain is now demonstrable: Kali/ZAP generates activity, crAPI and the edge log source produce security-relevant events, Wazuh decodes and matches the custom rule set, the custom integration enriches the event, and DFIR-IRIS receives the alert for triage. The next week should improve alert deduplication, IRIS case workflow, detailed IRIS detail-page screenshots, false-positive measurement, and complete coverage evidence for every rule family.

Keywords: SOC, Wazuh, DFIR-IRIS, crAPI, OWASP ZAP, Reconnaissance, Pentesting, Broken Access Control, PHP-CGI Option Injection, MITRE ATT&CK T1190, Alert Forwarding, Incident Response, Detection Engineering.

List of Acronyms

Acronym	Meaning
API	Application Programming Interface
BAC	Broken Access Control
BFLA	Broken Function Level Authorization
BOLA	Broken Object Level Authorization
BOPLA	Broken Object Property Level Authorization
DFIR	Digital Forensics and Incident Response
DQL	Dashboard Query Language
IDS	Intrusion Detection System
IR	Incident Response
IRIS	Incident Response Investigation System used for DFIR case and alert management
JWT	JSON Web Token
NAT	Network Address Translation
OSSEC	Open Source Security Event Correlator, the foundation used by Wazuh
SOC	Security Operations Center
TTP	Tactics, Techniques, and Procedures
WAF	Web Application Firewall
ZAP	Zed Attack Proxy, used here as OWASP ZAP

Contents

1	Weekly Progress Overview	1
1.1	Purpose of This Weekly Report	1
1.2	Completed Work This Week	1
1.3	Main Result	2
1.4	Current Project Status	2
2	Background and Continuity from Previous Weeks	2
2.1	Week 5: Rule Validation and Source-IP Blocker	2
2.2	Week 6: Real Source-IP Logging	2
2.3	Week 7 Objective	2
3	Updated Week 7 Architecture	3
3.1	Operational Alert Flow	3
3.2	Component Roles	3
4	DFIR-IRIS Integration Work	3
4.1	Integration Design	3
4.2	Forwarding Scope	3
4.3	Alert Context Sent to IRIS	3
4.4	Severity Mapping	4
5	Pentest and Reconnaissance Methodology	4
5.1	Authorized Lab Scope	4
5.2	OWASP ZAP Automated Scan	4
5.3	Recon Alert Families Observed by ZAP	5
5.4	Wazuh Evidence Capture Method	5
6	Evidence and Results	6
6.1	Wazuh High-Severity Event Evidence	6
6.2	DFIR-IRIS Queue Response	6
6.3	DFIR-IRIS Alert-List Evidence from Forwarded Wazuh Rules	7
6.4	End-to-End Validation Statement	9
7	Rule Engineering Context for Week 7	10
7.1	Recon and Web Attack Rule Families	10
7.2	Why the PHP-CGI Event Is Useful Evidence	10
8	SOC Analyst Interpretation and IRIS Triage	10
8.1	How an Analyst Should Read the Week 7 Alert	10
8.2	Example Triage Notes	11
9	Technical Challenges and Resolutions	11
10	Current Limitations	11
10.1	IRIS Evidence Is Alert-List Level, Not Full Detail-Page Level	11
10.2	ZAP Findings Are Mostly Recon and Hardening Findings	12
10.3	Request Body and Header Visibility Remains Limited	12
10.4	No Final Detection Metrics Yet	12
11	Plan for Week 8	12
11.1	Engineering Tasks	12
11.2	Expected Deliverables for the Next Report	12

12 Conclusion	13
A Appendix A: Key Commands and Checks	13
A.1 Check Wazuh and IRIS Network Connectivity	13
A.2 Check Wazuh Integration Logs	13
A.3 Recommended Wazuh Discover Query	13
A.4 Fields to Capture in Future Screenshots	13
B Appendix B: Week 7 Evidence Matrix	14
C References	14

1 Weekly Progress Overview

1.1 Purpose of This Weekly Report

The purpose of the Week 7 report is to document the progress that was missing from the previous weekly report format: the actual operational work completed this week, the evidence collected from pentest/recon activity, the response visible in DFIR-IRIS, and the remaining engineering tasks for the next iteration. The focus is no longer only rule syntax validation. The focus is now the full SOC workflow from attack simulation to SIEM alerting and IR response handling.

1.2 Completed Work This Week

Work item	Status	Evidence or result
DFIR-IRIS network integration	Completed	Wazuh manager and IRIS nginx were connected through a shared Docker network so that Wazuh can call the IRIS API using the internal alias <code>dfir-iris</code> .
IRIS API key workflow	Completed	API access was validated from inside the Wazuh manager container. The report does not include the API key value.
Custom Wazuh integration script	Completed	The <code>script /var/ossec/integrations/custom-wazuh_iris</code> was used to transform Wazuh alerts into IRIS alert payloads.
Wazuh integration rule scope	Completed	The forwarding condition was limited to <code>rule.level >= 10</code> and groups containing <code>bglobal</code> or <code>crapi</code> .
Reconnaissance test with OWASP ZAP	Completed	ZAP automated scan finished against <code>http://10.10.1.130:8888</code> and produced 13 alert families.
Wazuh row-level evidence	Completed for representative high-severity event	Wazuh Discover showed a level 10 bGlobal alert for PHP-CGI option injection with source IP <code>10.10.1.20</code> .
IRIS response validation	Completed at statistics and alert-list level	DFIR-IRIS Statistics page showed alert creation and unassigned alert queue updates. New IRIS alert cards also show forwarded Wazuh rules 110400, 110672, 110676, and 110311.
Week 8 improvement planning	Completed	Remaining issues were documented: deduplication, case workflow, detailed IRIS alert screenshots, field enrichment checks, and evidence coverage for every rule family.

1.3 Main Result

The main result is that Wazuh is no longer only a dashboard detection layer. It now acts as the upstream SIEM source for DFIR-IRIS. High-severity events can be converted into IRIS alerts with investigation context, including Wazuh alert ID, rule metadata, source IP, URL, status code, agent information, raw event content, and a Wazuh Dashboard search link.

1.4 Current Project Status

Area	Status		Comment
Lab deployment	Stable		crAPI, Wazuh, and IRIS are available for the SOC/IDS workflow.
Source-IP preservation	Validated Week 6	from	Wazuh web/API detections can include the Kali source IP 10.10.1.20.
Custom rule logic	Validated Week 5/6	from	Rule matching was already tested, and Week 7 added recon-focused rule families and live evidence.
Pentest/recon evidence	Partially dated	vali-	ZAP and controlled requests produced visible alerts. More attack categories still need individual row-level screenshots.
IRIS alert forwarding	Validated alert-list level	at	IRIS alert counts increased, the alert queue became populated, and multiple alert cards show Wazuh rule titles, severity, source, client, and tags. Detail-page field verification should be captured next.
Incident response workflow	In progress		Alert intake is working, but case creation, assignment, deduplication, and closure workflow still need tuning.

2 Background and Continuity from Previous Weeks

2.1 Week 5: Rule Validation and Source-IP Blocker

Week 5 established that the custom Wazuh rule logic could match the expected synthetic events. However, it also identified a serious evidence-quality issue: the live web layer could show a Docker or translated IP such as 172.20.0.2 instead of the real Kali attacker IP 10.10.1.20. This meant source-based triage and `same_srcip` correlation should not be overclaimed until the log path was corrected.

2.2 Week 6: Real Source-IP Logging

Week 6 corrected the logging path by moving crAPI to a dedicated Ubuntu VM and placing an edge reverse proxy in front of the crAPI web layer. That design allowed Wazuh events to carry the real source IP, HTTP method, URL, status code, and user-agent together in the same event. This was the necessary foundation for Week 7 because DFIR-IRIS should receive alerts that are useful for investigation, not only generic rule hits.

2.3 Week 7 Objective

The Week 7 objective was to validate the IR response phase: once Wazuh detects meaningful crAPI attack activity, the event should be forwarded to DFIR-IRIS with enough context for triage. This

includes attack source, affected endpoint, rule ID, severity, MITRE mapping, and a direct link back to the Wazuh event.

3 Updated Week 7 Architecture

3.1 Operational Alert Flow

Kali / OWASP ZAP → crAPI edge proxy and web logs → Wazuh agent → Wazuh Manager rules → custom-wazuh_iris integration → DFIR-IRIS Alerts

3.2 Component Roles

Component	Example identifier	Role in Week 7
Kali attacker/tester	10.10.1.20	Runs manual tests and OWASP ZAP recon against crAPI.
crAPI Ubuntu VM	10.10.1.130	Hosts the vulnerable API lab and edge web logging path.
Wazuh web-gateway agent	crapi-web-gateway	Collects web/API logs and sends them to Wazuh Manager.
Wazuh Manager	single-node-wazuh.manager-1	Decodes logs, applies custom bGlobal/crAPI rules, and triggers custom integration.
DFIR-IRIS nginx	iriswebapp_nginx	Receives Wazuh alert payloads through the IRIS API endpoint.
Shared Docker network	soc_shared	Provides internal connectivity between Wazuh Manager and DFIR-IRIS.

4 DFIR-IRIS Integration Work

4.1 Integration Design

The Wazuh-to-IRIS integration was implemented using a custom integration script and an internal Docker network. The Wazuh manager container calls the DFIR-IRIS API endpoint through <https://dfir-iris:8443/alerts/add?cid=1>. The script builds a structured IRIS alert and includes the original Wazuh event as source content so that the analyst can pivot back to the SIEM.

4.2 Forwarding Scope

The forwarding policy intentionally avoids sending every scan observation to IRIS. Only higher-severity detections are forwarded:

- Wazuh rule level must be 10 or higher.
- The event should belong to the custom `bglobal` or `crapi` rule groups.
- Low-severity recon observations remain in Wazuh for hunting and correlation.

4.3 Alert Context Sent to IRIS

Context field	Purpose
---------------	---------

<code>event_uuid</code>	Unique identifier generated for the IRIS alert source reference.
<code>wazuh_alert_id</code>	Original Wazuh event ID used to locate the exact event in Discover.
<code>wazuh_search_query</code>	Backup query such as <code>id:"1780490213.63528"</code> .
<code>rule_id, rule_level</code>	Wazuh detection identity and severity.
<code>srcip</code>	Source IP of the suspicious request, expected to be 10.10.1.20 for Kali tests.
<code>agent_name, agent_ip</code>	Wazuh agent/container that collected the event.
<code>url, status_code</code>	Web/API endpoint and HTTP response status.
<code>full_log</code>	Raw log content for forensic verification.

4.4 Severity Mapping

Wazuh level	IRIS severity ID	Meaning in this lab
7-9	4	Medium/high hunting signal, normally kept in Wazuh unless manually reviewed.
10-12	5	High severity, forwarded to IRIS for triage.
13 or higher	6	Critical or strong correlation event, should be prioritized for case handling.

5 Pentest and Reconnaissance Methodology

5.1 Authorized Lab Scope

All testing was performed against the local crAPI vulnerable API laboratory. The target used for the automated scan was <http://10.10.1.130:8888>. The goal was not to attack a third-party system, but to generate controlled evidence that Wazuh and IRIS can process during a SOC lab scenario.

5.2 OWASP ZAP Automated Scan

OWASP ZAP was used in automated scan mode. The target URL was set to <http://10.10.1.130:8888>. The traditional spider was enabled, and the AJAX spider option was configured with Firefox. The scan completed and the Alerts tab displayed 13 alert families.

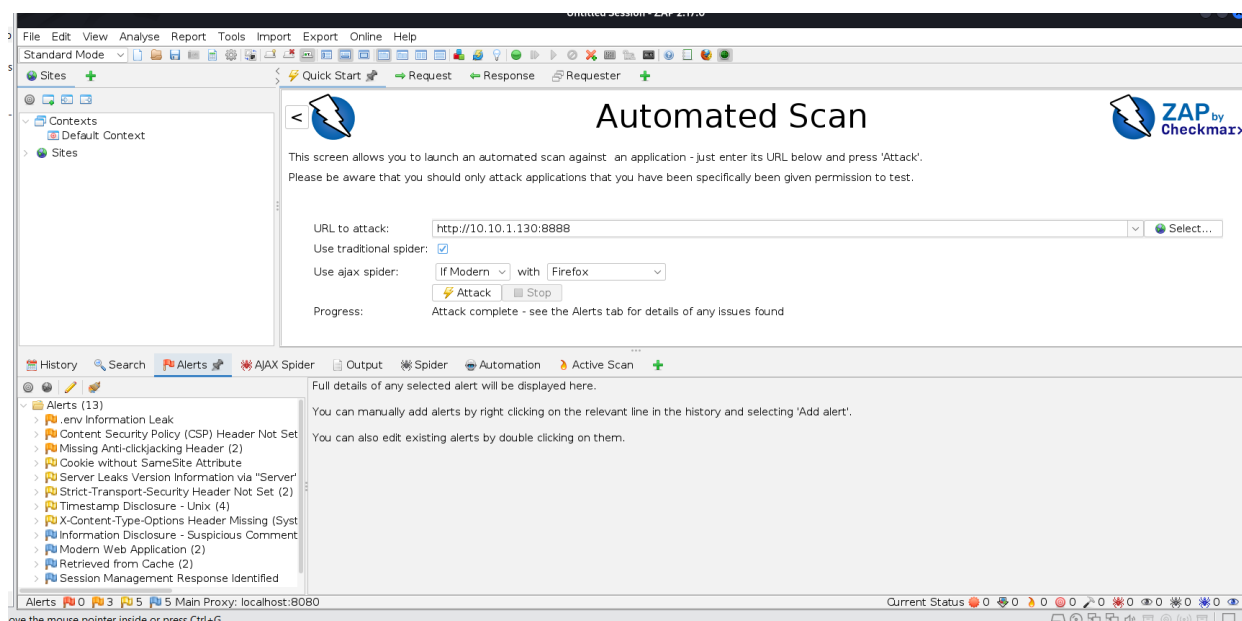


Figure 1: OWASP ZAP automated scan completed against crAPI on port 8888, producing 13 alert families.

5.3 Recon Alert Families Observed by ZAP

Observed alert family	SOC interpretation
Content Security Policy header not set	Security-header hardening issue that can increase browser-side attack exposure.
Missing Anti-clickjacking header	Potential clickjacking protection gap.
Cookie without SameSite attribute	Session/cookie hardening issue.
Server version information disclosure	Technology disclosure that can help attacker fingerprinting.
Strict-Transport-Security header not set	TLS hardening gap if the application is served over HTTPS.
Timestamp disclosure	Information leak that may help fingerprint the stack or application behavior.
X-Content-Type-Options header missing	Browser MIME-sniffing protection not enforced.
Suspicious comments and information disclosure	Reconnaissance finding that should be reviewed for accidental leakage.
Modern web application / session management observations	Informational context used during web application analysis.

5.4 Wazuh Evidence Capture Method

The Wazuh Dashboard Discover view was used to verify row-level event fields. The fields used for evidence review were `agent.name`, `agent.ip`, `data.srcip`, `data.id`, `data.protocol`, `data.url`, `rule.id`, `rule.level`, `rule.description`, `rule.groups`, and `full_log`. This is stronger than only counting alerts because it proves that the event contains the fields required for triage and IRIS enrichment.

6 Evidence and Results

6.1 Wazuh High-Severity Event Evidence

The Wazuh Discover screenshot shows a representative high-severity event generated during the pentest/recon validation phase. The event was collected by the `crapi-web-gateway` agent. It contains source IP `10.10.1.20`, HTTP status `405`, and a suspicious URL containing PHP-CGI option injection indicators. The rule description shown in the dashboard is `bGlobal: PHP-CGI Option Injection Attempt Observed`, and the rule level is `10`.

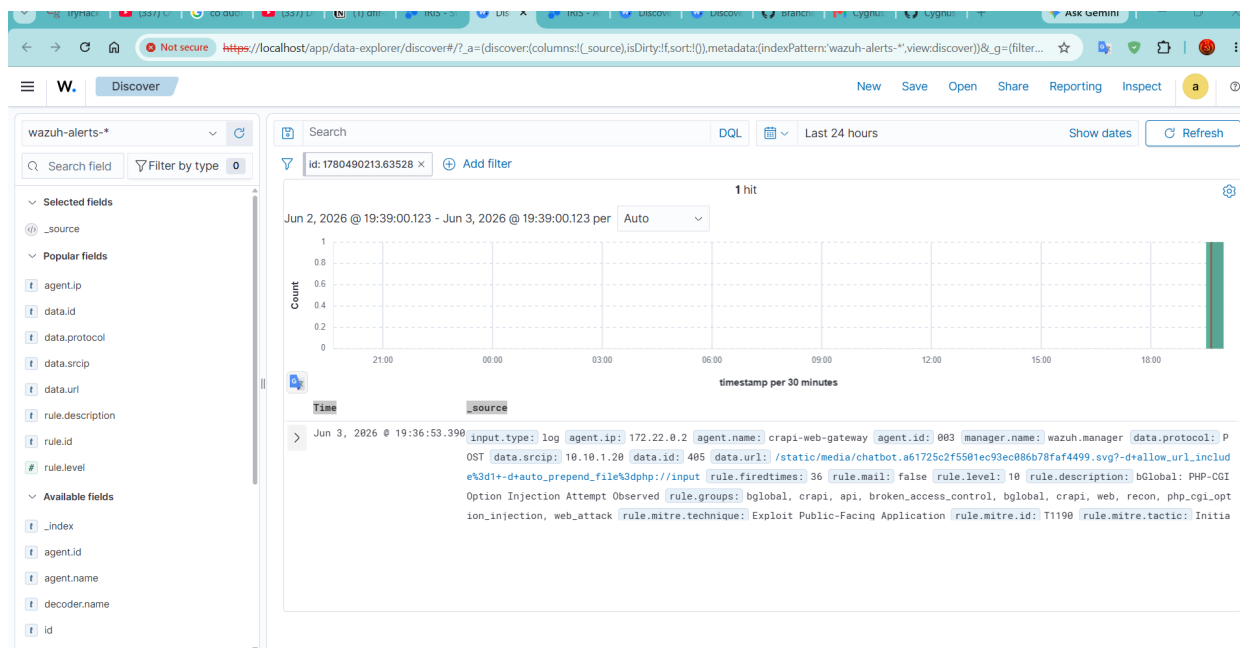


Figure 2: Wazuh Discover row-level evidence for a high-severity PHP-CGI option injection alert.

Field	Observed value / interpretation
Wazuh alert ID	1780490213.63528
Time shown in Discover	Jun 3, 2026 @ 19:36:53.390
Agent	crapi-web-gateway / agent ID 003
Agent IP	172.22.0.2 as the container or agent-side address
Source IP	10.10.1.20, matching the Kali attacker/tester machine
HTTP status	405, indicating that the endpoint or method was not allowed
URL pattern	Static chatbot media path with PHP-CGI option injection style parameters
Rule description	bGlobal: PHP-CGI Option Injection Attempt Observed
Rule level	10, high enough to be forwarded into DFIR-IRIS
MITRE mapping	T1190 - Exploit Public-Facing Application

6.2 DFIR-IRIS Queue Response

The DFIR-IRIS Statistics page shows that the alert queue has been populated. The screenshot shows **Alerts Created = 64**, **Unassigned Alerts = 62**, **Status New = 62**, and **Resolution Unknown/Unset = 63**. This confirms that IRIS is receiving or retaining alert objects for triage. The new evidence added in this version also includes IRIS alert-list screenshots, so the report now proves more than

queue population: it shows individual Wazuh-derived alert cards with rule titles, severity, source, client, and tags. The remaining gap is full IRIS detail-page verification for context JSON and Source Link accuracy.

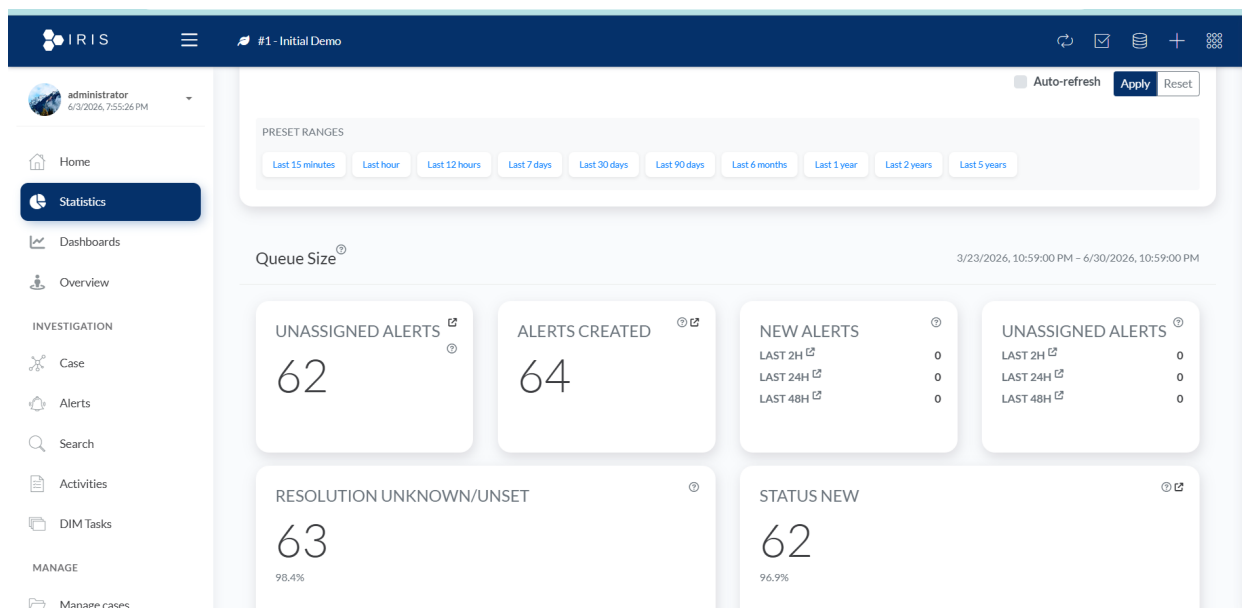


Figure 3: DFIR-IRIS Statistics page showing populated alert queue after Wazuh integration validation.

IRIS metric	Observed value	Interpretation
Alerts created	64	IRIS contains alert objects created during testing and validation.
Unassigned alerts	62	Most alerts still require analyst assignment or automated routing.
Status new	62	Intake is working, but triage state transitions have not yet been fully operationalized.
Resolution unknown/unset	63	Alert closure and resolution workflow must be improved next week.
New alerts in last 2h/24h/48h	0 in the screenshot	The visible time filter may not include the exact latest generated alert time, or the queue reflects historical/previous test alerts. This should be checked with per-alert detail pages.

6.3 DFIR-IRIS Alert-List Evidence from Forwarded Wazuh Rules

The updated Week 7 evidence includes individual IRIS alert cards. These screenshots are important because they show that high-severity Wazuh detections are not only counted in the queue; they are visible as separate triage objects in IRIS with Wazuh rule titles, alert references, source, client, severity, and tags.

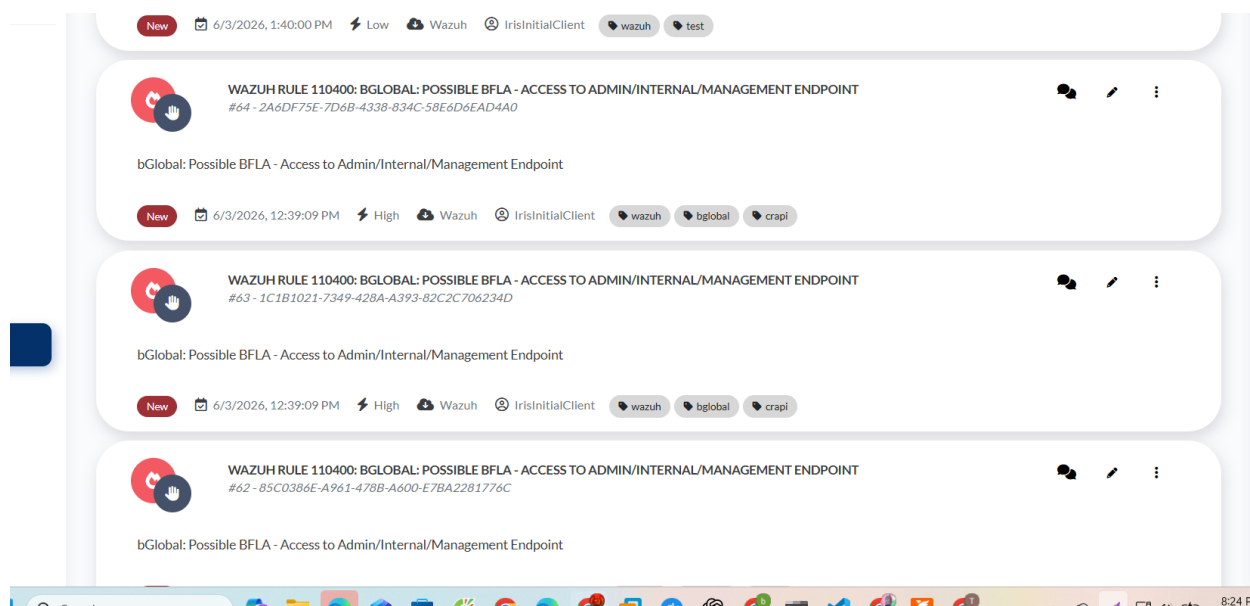


Figure 4: DFIR-IRIS alert-list evidence showing forwarded Wazuh rule 110400: possible BFLA access to an admin/internal/management endpoint.

The first IRIS screenshot shows repeated high-severity BFLA-related alert cards. The visible alert title is WAZUH RULE 110400: BGLOBAL: POSSIBLE BFLA - ACCESS TO ADMIN/INTERNAL/MANAGEMENT ENDPOINT. The visible cards include IRIS references such as #64, #63, and #62. Each card is marked New, has severity High, uses Wazuh as the source, shows IrisInitialClient, and includes tags such as wazuh, bglobal, and crapi. This is stronger than a general statistics screenshot because it confirms that the BFLA rule is entering the IRIS analyst queue.

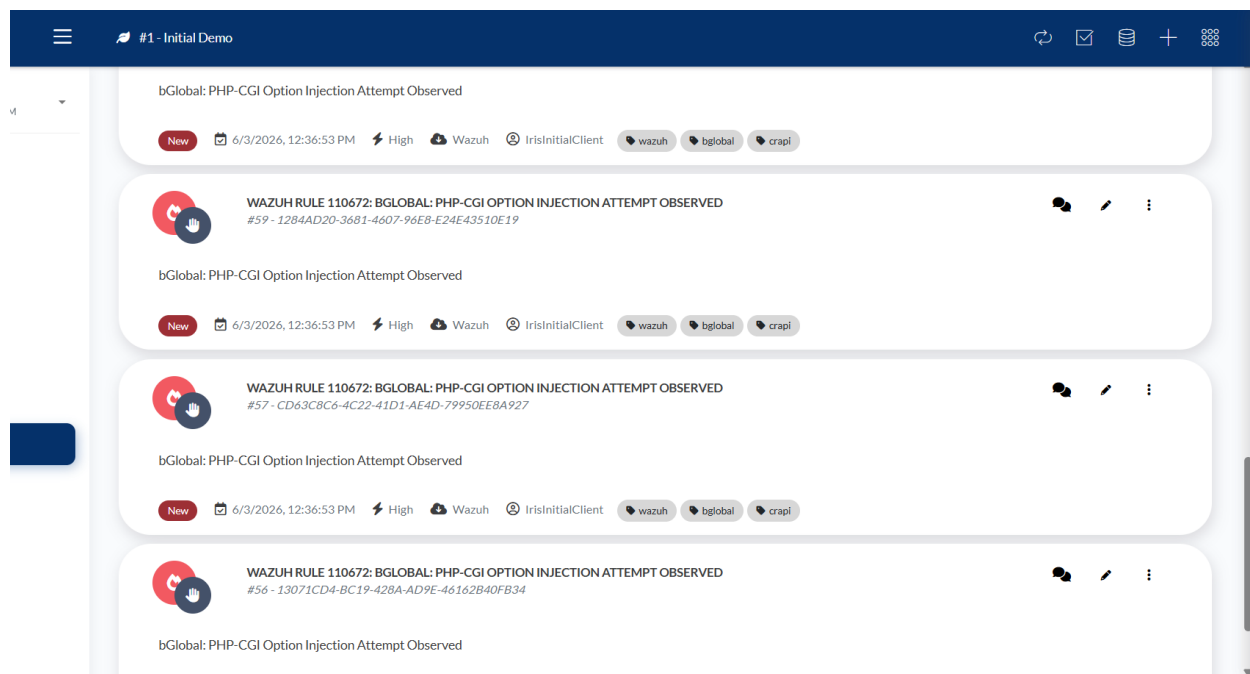


Figure 5: DFIR-IRIS alert-list evidence showing forwarded Wazuh rule 110672: PHP-CGI option injection attempt observed.

The second IRIS screenshot shows high-severity PHP-CGI option injection alerts. The visible alert title is WAZUH RULE 110672: BGLOBAL: PHP-CGI OPTION INJECTION ATTEMPT OBSERVED. Visible IRIS references include #59, #57, and #56, with timestamp 6/3/2026, 12:36:53 PM. The cards are tagged wazuh, bglobal, and crapi. This matches the Wazuh evidence for PHP-CGI option injection

and confirms that this high-severity rule family is being forwarded into IRIS.

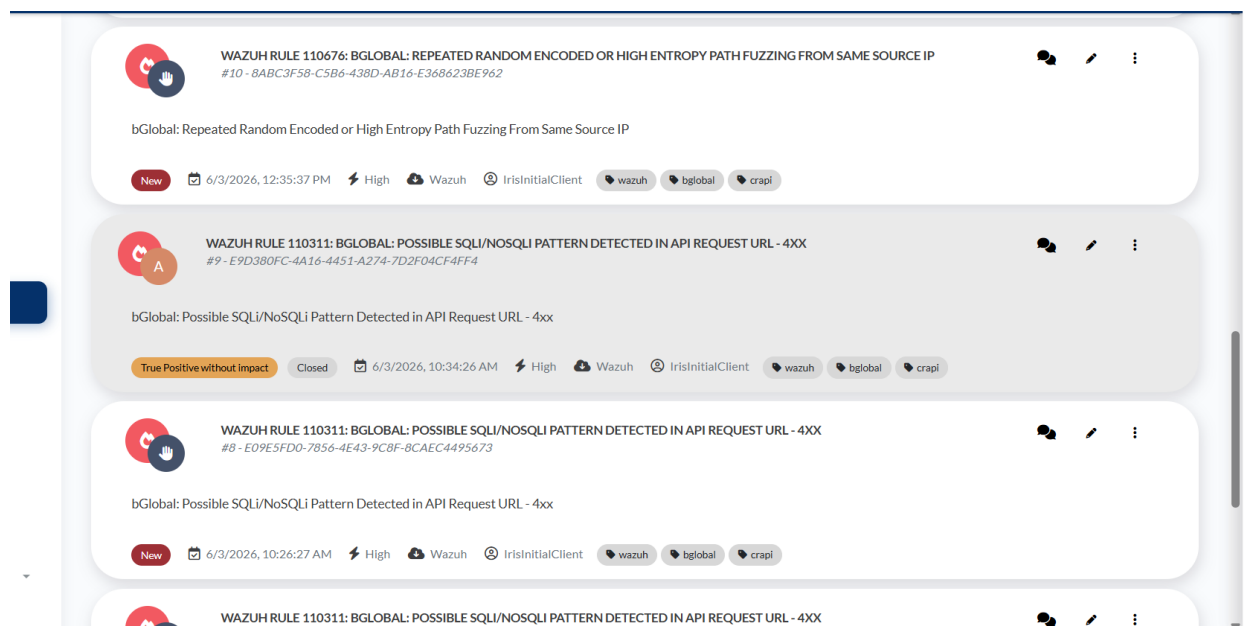


Figure 6: DFIR-IRIS alert-list evidence showing high-entropy path fuzzing and SQLi/NoSQLi URL pattern alerts from Wazuh.

The third IRIS screenshot expands the evidence beyond one exploit family. It shows rule 110676: repeated random encoded or high-entropy path fuzzing from the same source IP, and rule 110311: possible SQLi/NoSQLi pattern detected in an API request URL with a 4xx response. One SQLi/NoSQLi alert is marked **Closed** with the resolution **True Positive without impact**, which demonstrates that IRIS can be used not only for alert intake but also for triage state tracking.

IRIS evidence	Visible Wazuh rule	Interpretation
BFLA alert cards	110400 - possible BFLA access to admin/internal/management endpoint	Confirms that admin/internal endpoint access detections are forwarded into IRIS as high-severity triage objects.
PHP-CGI alert cards	110672 - PHP-CGI option injection attempt observed	Confirms that exploit-oriented web attack detections are forwarded and visible in the analyst queue.
High-entropy fuzzing	110676 - repeated random encoded or high-entropy path fuzzing from same source IP	Shows correlation-style recon/fuzzing behavior can become an IRIS alert.
SQLi/NoSQLi pattern	110311 - possible SQLi/NoSQLi pattern in API request URL - 4xx	Shows injection-oriented detection and triage handling; one alert is already closed as true positive without impact.

6.4 End-to-End Validation Statement

The Week 7 evidence supports the following end-to-end chain:

1. Reconnaissance and pentest traffic was generated against crAPI.
2. The web/API logging layer produced events with triage fields.
3. Wazuh decoded the event and matched a custom bGlobal/crAPI rule.
4. A high-severity Wazuh event was eligible for forwarding because its rule level was 10.

5. DFIR-IRIS showed both a populated alert queue and individual forwarded Wazuh alert cards for response handling.

7 Rule Engineering Context for Week 7

7.1 Recon and Web Attack Rule Families

The Week 7 rule set includes broader reconnaissance coverage than the previous reports. In addition to BOLA/IDOR, BFLA, SSRF, SQLi/NoSQLi, JWT, and Mass Assignment heuristics, the rule file now includes rules for scanner user-agents, upload/plugin probing, generic PHP/CMS enumeration, suspicious HTTP methods, generic exploit payloads, raw Nginx warning logs, VCS/source-control probing, secret/config file probing, cloud metadata probing, framework fingerprinting, PHP tooling probes, PHP-CGI option injection, high-entropy path fuzzing, common discovery files, and HTTP 400 bursts.

Rule ID / family	Detection topic	Week 7 relevance
110600	Scanner user-agent	Useful for identifying OWASP ZAP, OpenVAS, Nikto, sqlmap, Nuclei, ffuf, and similar recon tools.
110610-110612	Upload/plugin probing	Covers known upload handler and plugin paths often hit by automated scanners.
110620-110621	Generic PHP/CMS enumeration	Captures repeated requests to common PHP/CMS paths.
110640	Generic exploit payload indicators	Covers path traversal, XSS, RCE-like query parameters, and SQLi strings in URLs.
110650-110651	Raw Nginx warning logs	Adds visibility when standard decoded URL fields are incomplete.
110660-110679	Expanded recon coverage	Covers VCS, secret/config files, cloud metadata, framework fingerprinting, PHP tooling, high-entropy fuzzing, common discovery files, and 400 bursts.
110672-110674	PHP-CGI option injection	Relevant to the Week 7 representative Wazuh evidence.

7.2 Why the PHP-CGI Event Is Useful Evidence

The PHP-CGI option injection event is useful because it demonstrates more than generic scanning. It shows that Wazuh can tag a concrete exploit-style pattern, assign a high severity level, map the activity to MITRE ATT&CK T1190, and preserve the source IP needed for investigation. This makes it an appropriate candidate for DFIR-IRIS forwarding.

8 SOC Analyst Interpretation and IRIS Triage

8.1 How an Analyst Should Read the Week 7 Alert

An analyst should treat the Week 7 event as a high-severity web exploitation attempt observed during authorized lab testing. The source 10.10.1.20 is the tester/attacker host. The destination context is the crAPI web gateway. The suspicious URL contains option-injection style parameters. The response status 405 means the request was not accepted as a normal resource action, but the attempt still matters because it indicates scanner or exploit behavior against a public-facing application surface.

8.2 Example Triage Notes

Triage field	Recommended analyst note
Classification	Reconnaissance / exploit attempt against web/API surface.
Source	Kali tester 10.10.1.20.
Technique	MITRE ATT&CK T1190 - Exploit Public-Facing Application.
Affected component	crAPI web gateway and static media route.
Severity	High, because rule level is 10 and the pattern is exploit-oriented.
Immediate action	Confirm whether the request came from authorized testing; if not, block or investigate the source.
IRIS handling	Assign to analyst, add Wazuh alert ID, verify Source Link, group with other alerts from the same source IP, and close as test activity only after evidence is documented.

9 Technical Challenges and Resolutions

Challenge	Impact	Resolution / current handling
Wazuh-to-IRIS network reachability	Wazuh could not forward alerts if it could not resolve or reach IRIS.	Both containers were attached to <code>soc_shared</code> ; the internal alias <code>dfir-iris</code> is used.
API key security	Exposed keys would allow unauthorized alert creation or API access.	The key is not stored in the report. If exposed in screenshots, it must be renewed.
Integration script execution	CRLF line endings or wrong permissions can prevent execution.	Script line endings and permissions were corrected; the script is placed under the Wazuh integrations directory.
Alert noise	Recon scans can generate many medium/low-value alerts.	Only rule level 10+ bGlobal/crAPI alerts are sent to IRIS. Lower-level events remain in Wazuh.
Source link accuracy	IRIS Source Link must return to the exact Wazuh event.	The script stores both a clickable link and backup query such as <code>id:"..."</code> .
Queue management	IRIS shows many unassigned/new alerts.	Next week should add assignment, deduplication, and closure workflow.

10 Current Limitations

10.1 IRIS Evidence Is Alert-List Level, Not Full Detail-Page Level

The updated IRIS screenshots prove that forwarded Wazuh alerts are visible as individual alert cards, not only as aggregate queue statistics. They show titles, IRIS references, status, severity,

source, client, and tags. However, the screenshots still do not show every forwarded context field. The next evidence set should open a specific IRIS alert and capture the source reference, source link, severity mapping, tags, context JSON, and raw Wazuh source content.

10.2 ZAP Findings Are Mostly Recon and Hardening Findings

The ZAP screenshot shows useful recon and security-header findings, but many are not direct Broken Access Control exploitation evidence. They should be used as recon and exposure context, while BOLA/IDOR, BFLA, authentication abuse, SSRF, injection, and method-abuse tests should be captured separately.

10.3 Request Body and Header Visibility Remains Limited

Default web access logs usually show source IP, method, URL, status, and user-agent, but not full request bodies or sensitive authorization headers. Accurate JWT and Mass Assignment detection may require safe application logs, WAF logs, or masked body/header logging.

10.4 No Final Detection Metrics Yet

The project has not yet produced a full benign/malicious dataset with false-positive and false-negative measurements. The report should not claim final detection accuracy until such a dataset is built.

11 Plan for Week 8

11.1 Engineering Tasks

1. Capture per-alert DFIR-IRIS detail screenshots for at least three forwarded Wazuh alerts.
2. Verify that IRIS Source Link opens Wazuh Discover with the correct `id:"..."` query.
3. Add deduplication logic so repeated scanner hits do not create excessive duplicate IRIS alerts.
4. Create IRIS case-management workflow: assign analyst, set severity, add notes, link related alerts, and close resolved test alerts.
5. Build an evidence matrix for each rule family: expected attack, expected rule ID, observed Wazuh rule ID, source IP, status code, IRIS alert ID/reference, and screenshot path.
6. Rerun BOLA/IDOR, BFLA, authentication scanning/brute force, SSRF, SQLi/NoSQLi, path traversal, PHP-CGI option injection, and scanner-user-agent tests.
7. Add baseline normal traffic and measure which rules fire during benign use of crAPI.
8. Improve integration logging with retry/backoff and clear errors for API failures.
9. Protect secrets by keeping API keys out of reports, screenshots, and Git history; renew any exposed key.
10. Add log rotation for Wazuh integration logs and proxy logs to prevent disk growth.

11.2 Expected Deliverables for the Next Report

Deliverable	Expected value
IRIS detail-page screenshot	Opens a specific Wazuh alert inside IRIS and verifies source reference, Source Link, context JSON, raw source content, and severity mapping.
Wazuh-to-IRIS mapping table	Maps Wazuh alert ID to IRIS source reference or alert ID.
Rule-family coverage table	Shows which attack categories have Wazuh row-level evidence and IRIS evidence.

Deduplication test	Demonstrates that repeated scanner events do not flood IRIS unnecessarily.
Case workflow evidence	Shows assigned/triaged/resolved status changes in IRIS.
Baseline traffic result	Separates normal crAPI activity from malicious or recon activity.

12 Conclusion

Week 7 moved the project from detection validation into response workflow validation. The Wazuh rules and source-IP logging were already improved in previous weeks. This week confirmed that high-severity Wazuh events can be forwarded into DFIR-IRIS and that reconnaissance activity against crAPI produces usable evidence in both Wazuh and IRIS. The strongest updated evidence is the set of IRIS alert cards for Wazuh rules 110400, 110672, 110676, and 110311, together with the Wazuh row-level evidence for the PHP-CGI option injection event from source IP 10.10.1.20.

The project should not yet claim final SOC maturity because IRIS case workflow, deduplication, per-alert detail evidence, and detection metrics still need work. However, the core chain is now working: attacker simulation, log collection, Wazuh detection, high-severity filtering, custom integration, and DFIR-IRIS alert intake. Week 8 should focus on improving evidence depth and turning alert intake into a repeatable incident-response process.

A Appendix A: Key Commands and Checks

A.1 Check Wazuh and IRIS Network Connectivity

```
docker ps --format "table {{.Names}}\t{{.Networks}}" | grep -E "iriswebapp_nginx|single-node-wazuh.manager"
docker exec -it single-node-wazuh.manager-1 bash -lc 'getent hosts dfir-iris'
docker exec -it single-node-wazuh.manager-1 bash -lc 'curl -k -I https://dfir-iris:8443'
```

A.2 Check Wazuh Integration Logs

```
docker exec -it single-node-wazuh.manager-1 bash -lc '
tail -n 80 /var/ossec/logs/integrations.log
grep -i "custom-wazuh_iris\|integrat\|error" /var/ossec/logs/ossec.log | tail -n 80
'
```

A.3 Recommended Wazuh Discover Query

```
rule.level >= 10 and rule.groups:bglobal
id:"1780490213.63528"
```

A.4 Fields to Capture in Future Screenshots

```
agent.name
agent.ip
data.srcip
data.id
data.protocol
data.url
rule.id
rule.level
rule.description
rule.groups
```

```
rule.mitre.id
full_log
```

B Appendix B: Week 7 Evidence Matrix

Evidence	Observed value	Status	Next action
ZAP scan	13 alert families against <code>h t t p : //10.10.1.130:8888</code>	Captured	Export ZAP report and map findings to Wazuh logs.
Wazuh PHP-CGI event	id:1780490213.63528, level 10, source 10.10.1.20	Captured	Capture expanded row with <code>rule.id</code> .
IRIS statistics	64 alerts created, 62 unassigned, 62 new	Captured	Use as aggregate queue evidence.
Source-IP preservation	<code>data.srcip=10.10.1.20</code> in Wazuh evidence	Validated for representative event	Confirm across all rule families.
IRIS BFLA alert cards	Rule 110400, visible references #64, #63, #62, severity High	Captured	Open detail page and verify context JSON.
IRIS PHP-CGI alert cards	Rule 110672, visible references #59, #57, #56, severity High	Captured	Map to exact Wazuh IDs.
IRIS fuzzing/injection cards	Rules 110676 and 110311, including one closed true-positive/no-impact item	Captured	Use for triage workflow evidence.
Wazuh-to-IRIS pipeline	High-severity forwarding operational	Validated with alert cards	Add deduplication and case workflow.

C References

1. Internal project report, Week 5: Rule Validation and NAT Source-IP Troubleshooting Phase.
2. Internal project report, Week 6: Ubuntu Migration, NAT/IP Forwarding, and Real Source-IP Logging Phase.
3. Internal project guide: Wazuh - DFIR-IRIS Integration Guide, Version 1.0, June 3, 2026.
4. Internal custom rule file: bGlobal/crAPI Wazuh rule set for Broken Access Control, recon, injection, and web attack visibility.